

Top 10 web hacking techniques of 2020 - nominations open



James Kettle

Director of Research

[@albinowax](#)



Published: Tuesday, 5 January 2021 at 14:01 UTC

Updated: Wednesday, 24 February 2021 at 15:37 UTC

Update: [The top ten is now out!](#)

Nominations are now open for the top 10 new web hacking techniques of 2020!

2020 was not an ideal year for many of us, but that didn't stop the security community from sharing a broad array of novel research ranging from creative iterations on existing work to entire new attack concepts. Keeping up with this flood of posts can be exhausting in the best of times, so every year we collaborate with the community to first identify all the key research releases, then whittle the list down to the top ten must-see new techniques. Take a look at [last year's top 10](#) to see what this looks like. For researchers, the nomination list is also a valuable asset - check out [2019's superb nomination list](#).

We'll follow the same battle-tested process as usual:

- **Jan 05:** Start to collect community nominations
- **Jan 18:** Launch community vote to build shortlist of top 15
- **Feb 07:** Launch panel vote on shortlist to select and order the 10 finalists
- **Feb 22:** Publish top 10 of 2020!

Everyone is welcome to nominate a piece of research, just use [the nomination form](#).

Feel free to nominate your own research if you think it's worthy. We know too well that some quality work gets overlooked just because it isn't social-media optimized.

We love to see all kinds of security knowledge being shared but we're aiming to list only posts that contain a novel technique, idea or concept that can be reapplied elsewhere. As such, just like last year I will enforce a minimum quality bar to prevent the nomination list from being flooded with posts that merely show the application a technique that's already been publicly documented. If you're looking for techniques that have been around a while but won't go away, check out the OWASP Top Ten.

If you're interested in hearing about novel techniques the moment they come out, you can follow [@PortSwiggerRes](#) on Twitter, or subscribe to [r/websecurityresearch](#). I've used these sources to make a few nominations to get things started. This list will get updated regularly during the nomination phase.

Finally, here's the complete list of past year's top 10s:

[2019](#), [2018](#), [2017](#), [2015](#), [2014](#), [2013](#), [2012](#), [2011](#), [2010](#), [2009](#), [2008](#), [2007](#), [2006](#).

Nominations so far:

- [Write-up for a Path Traversal on Gravitee.io](#)
- [Fastjson: exceptional deserialization vulnerabilities](#)
- [Room for Escape: Scribbling Outside the Lines of Template Security](#)
- [Web Cache Entanglement: Novel Pathways to Poisoning](#)
- [TLS-poison](#)
- [HTTP Request Smuggling in 2020](#)
- [h2c Smuggling: Request Smuggling Via HTTP/2 Cleartext \(h2c\)](#)
- [Redefining Impossible: XSS without arbitrary JavaScript](#)
- [The Curious Case of Copy & Paste - on risks of pasting arbitrary content in browsers](#)
- [Mutation XSS via namespace confusion - DOMPurify < 2.0.17 bypass](#)
- [Salesforce Lightning - An in-depth look at exploitation vectors for the everyday community](#)
- [Advanced MSSQL Injection Tricks](#)
- [SD-PWN Part 2 — Citrix SD-WAN Center](#)
- [Portable Data exfiltration: XSS for PDFs](#)
- [Blind SQL Injection without an "in"](#)
- [Chaining Exposed Actuators and H2 Database Aliases in Spring Boot 2](#)
- [Exploiting email address parsing with AWS SES](#)
- [Revisiting ReDoS: A Rough Idea of Data Exfiltration by ReDoS and Side-channel Techniques](#)
- [Attacking Secondary Contexts in Web Applications](#)
- [Exploiting POST-based XSSI](#)
- [Uninitialized Memory Disclosures in Web Applications](#)
- [Researching Polymorphic Images for XSS on Google Scholar](#)
- [Secret fragments: Remote code execution on Symfony based websites](#)
- [The unexpected Google wide domain check bypass](#)
- [Marginwidth/marginheight - the unexpected cross-origin communication channel](#)
- [CSS data exfiltration in Firefox via a single injection point](#)
- [ImageMagick - Shell injection via PDF password](#)
- [Forcing Firefox to Execute XSS Payloads during 302 Redirects](#)
- [TURN server allows TCP and UDP proxying to internal network](#)
- [AST Injection, Prototype Pollution to RCE](#)
- [Bypass SameSite Cookies Default to Lax and get CSRF](#)
- [Covert Web Shells in .NET with Read-Only Web Paths](#)
- [A Security Review of SharePoint Site Pages](#)
- [My hacking adventures with Safari reader mode](#)
- [Code injection in Workflows leading to SharePoint RCE](#)
- [The Powerful HTTP Request Smuggling](#)
- [NAT Slipstreaming](#)
- [Smuggling HTTP headers through reverse proxies](#)
- [XXE-scape through the front door: circumventing the firewall with HTTP request smuggling](#)
- [Exploiting "Google BigQuery" SQL Injection Vulnerability](#)
- [WAF evasion techniques](#)
- [Exploiting dynamic rendering engines to take control of web apps](#)
- [Unauthenticated RCE on MobileIron MDM](#)
- [Blind SSRF exploitation](#)
- [Story of a weird vulnerability I found on Facebook](#)

- [Weird Vulnerabilities Happening on Load Balancers, Shallow Copies and Caches](#)
- [Unauthorized Google Maps API Key Usage Cases](#)
- [XSS fun with animated SVG](#)
- [Exploiting HSQLDB](#)
- [Real-life OIDC Security \(II\): Login Confusion](#)
- [Security and Privacy of Social Logins](#)
- [Cache-Key Normalization | What could go wrong?](#)
- [Hacking AWS Cognito Misconfigurations](#)
- [Attacking MS Exchange Web Interfaces](#)

top-10-techniques

← [Back to all articles](#)

Related Research



Burp Suite

Web vulnerability scanner
Burp Suite Editions
Release Notes

Vulnerabilities

Cross-site scripting (XSS)
SQL injection
Cross-site request forgery
XML external entity injection
Directory traversal
Server-side request forgery

Customers

Organizations
Testers
Developers

Company

About
Careers
Contact
Legal
Privacy Notice
Modern Slavery Statement

Insights

Web Security Academy
Blog
Research
Engineering

 **PortSwigger**

 [Follow us](#)

© 2026 PortSwigger Ltd.

